

EAAA Robotics A/S – Casebesvarelse

Opgave 1 – CIA-modellen og afledte tiltag

1.1 Hvordan virksomheden er ramt på CIA

CIA-element	Hvordan EAAA Robotics er ramt	Konkrete eksempler
Confidentiality (fortrolighed)	Brudt – følsomme forretnings- og persondata er eksfiltreret og kan misbruges.	Angriberne eksfiltrerer ca. 35 GB data: CAD-filer, AI-modeller, kontrakter, fakturaer, kundelister og kontooplysninger.
Integrity (integritet)	Undergravet – data og forretningsprocesser kan ikke længere stole på.	Falske fakturaer udsendes til to af virksomhedens største kunder. Ransomware ændrer (krypterer) data, så de ikke længere er i original tilstand.N
Availability (tilgængelighed)	Kraftigt ramt – kritiske systemer utilgængelige i flere dage, RTO/RPO massivt overskredet.	Hele netværket krypteres, produktionen står stille i 5 dage, og 10 dages data går tabt, selv backup er krypteret.

Supplering fra BIA-data:

BIA'en peger på, at *produktion af robotløsninger* og *R&D* er “meget kritiske” processer, og at *Dynamics 365* (økonomi/ordrer) samt *M365* (kommunikation) er centrale aktiver.

RTO/RPO-kravene (fx RTO 24 timer for produktion og RPO < 4 timer) blev klart overskredet, da produktionen stod stille i 5 dage og 10 dages data forsvandt.

1.2 Tiltag/initiativer, angrebet giver anledning til – og hvorfor

Nedenfor er tiltag delt i **organisatoriske**, **tekniske** og **beredskabs-/procesmæssige** tiltag.

a) Organisatoriske tiltag

- **Gøre cybersikkerhed til et ledelsesansvar**
 - Bestyrelse og direktion skal have et klart ansvar for informationssikkerhed og risikostyring – ikke kun IT-afdelingen.
 - Angrebet viste, at ledelsen undervurderede truslen (“vi er ikke interessante for hackere”).
- **Formel informationssikkerhedspolitik og governance**
(udbygges i Opgave 2C)

- Politikken skal fastlægge risikovillighed (risk appetite), roller, ansvar, krav til styring og rapportering.
- Kobles direkte til BIA og risikovurderinger, så ressourcer bruges på de mest kritiske processer.
- **Awareness og træning**
 - Løbende phishing-træning, awareness-kampagner og onboarding-træning for nye medarbejdere.
 - Angrebet startede med spear-phishing mod en økonomimedarbejder → klik på falsk login.
- **Incident response-øvelser**
 - Tabletop-øvelser (gennemgang på papir) og tekniske øvelser, så roller, processer og kommunikation afprøves i fredstid.

b) Tekniske tiltag

- **Multifaktorgodkendelse (MFA) overalt**
 - MFA skal være standard for *alle* brugere og særligt for administrative konti.
 - I casen var MFA kun for direktionen, og en administrativ konto uden MFA blev udnyttet til at tilgå interne servere.
- **Styrket identitets- og adgangsstyring**
 - Princip om *mindste privilegium*: brugere og systemer får kun de rettigheder, de faktisk behøver.
 - Regelmæssig gennemgang af privilegerede konti, afvikling af gamle konti, stærke passwordpolitikker.
- **Segmentering af netværk og “zero trust”*
 - Skarp adskillelse mellem kontornet (M365, Dynamics) og produktionsnetværk/PLC.
 - Ransomware ramte både produktionssystemer og backup, fordi alt var på samme netværk.
- **Backup-strategi efter 3-2-1-princippet**
 - 3 kopier af data, 2 forskellige medier/teknologier, 1 offline/immutable.
 - BIA'en viser, at NAS-backup er kritisk aktiv, men “vist utilstrækkelig”, hvilket blev bekræftet under angrebet.
 - Regelmæssig test af gendannelse op mod definerede RTO/RPO.
- **Patching og sårbarhedsstyring**
 - Fra kvartalsvise opdateringer til løbende patchproces med prioritering af kritiske sårbarheder.
 - Kombineres med sårbarhedsscanning og evt. penetrationstest.
- **Overvågning og logning**
 - Central logopsamling (SIEM/monitorering) for M365, Dynamics, servere og netværk.
 - Alarmering på mistænkelige login, masse-download, uautoriserede ændringer, mv.
 - I casen fandtes hverken overvågning eller central logning.
- **Beskyttelse af kritiske forretningsaktiver**
 - AI-modellen til ARM-X og CAD-filer skal behandles som *strategiske kerneaktiver*.
 - Kryptering i hvile og under transport, begrænset adgang, kode- og model-repository med stærk kontrol, DLP-mekanismer.

c) Beredskabs- og procesmæssige tiltag

- **Formel beredskabsplan (incident response + business continuity)**

- Tydelig aktivering: hvornår går man i beredskab, hvem beslutter hvad.
 - Klar prioritering: genskab først M365 (kommunikation), derefter produktionsnetværk, Dynamics 365 osv. i tråd med BIA-prioriteringen.
 - **Business Impact Analysis (BIA) som styringsværktøj**
 - Den eksisterende BIA giver RTO/RPO for kritiske processer – disse skal løbende opdateres og bruges til at dimensionere backup, redundans og beredskab.
 - **Plan for håndtering af løsesumskrav og kommunikation**
 - På forhånd definere principper for betaling/ikke-betaling, involvering af politi, forsikringsselskab, kunder og PR.
-

Opgave 2A – Modenhedsvurdering (NIST CSF)

2A.1 Områder med lavest modenhed før hændelsen

Med udgangspunkt i casen er følgende områder klart lavest modent:

- **Governance og risikostyring**
 - Ingen formaliserede, ledelsesgodkendte politikker.
 - Ingen systematisk risikovurdering koblet til forretningen.
- **Identity & Access Management (IAM)**
 - MFA kun på direktionsniveau, ikke på alle brugere og admin-konti.
 - En admin-konto uden MFA blev misbrugt til at tilgå interne servere.
- **Awareness og træning**
 - Medarbejder kompromitteres af phishing uden at opdage det.
- **Logning, overvågning og detektion**
 - Ingen central logopsamling eller overvågning af netværket.
- **Backup, beredskab og gendannelse**
 - Backup på samme netværk som produktionsmiljøet → også krypteret.
 - Ingen testede beredskabs- eller gendannelsesprocedurer.
- **Change- og patchmanagement**
 - Sikkerhedsopdateringer kun kvartalsvist.

2A.2 Valg af modenhedsmodel

Jeg anvender **NIST CSF** med de fire implementeringsniveauer (Tiers):

- **Tier 1 – Partial**
- **Tier 2 – Risk Informed**
- **Tier 3 – Repeatable**
- **Tier 4 – Adaptive**

2A.3 Modenhed før og efter foreslåede tiltag

Før hændelsen (overordnet):

Virksomheden ligger samlet på **Tier 1 – Partial**:

- Sikkerhed håndteres ad hoc.
- Beslutninger om sikkerhed er ikke systematisk koblet til forretningsrisici.
- Ingen formaliserede processer for incident response og BCP.

Efter implementering af foreslåede tiltag:

Målet er at løfte virksomheden til gennemsnitligt **Tier 2 – Risk Informed**, og på enkelte områder nærme sig **Tier 3 – Repeatable**.

NIST-funktion	Før	Efter (målbillede)	Begrundelse
Identify (aktiver, risici, governance)	Tier 1	Tier 2–3	BIA er etableret og udvides; formelle politikker og risikovurderinger bliver integreret i styringen.
Protect (kontroller, IAM, awareness)	Tier 1	Tier 2–3	Udbredt MFA, netværkssegmentering, forbedret backup, awareness-program, opdaterede tekniske kontroller.
Detect (overvågning og alarmer)	Tier 1	Tier 2	Central logopsamling og basale alarmer etableres; stadig udviklingsområde.
Respond (incident response)	Tier 1	Tier 2	Simpel beredskabsplan og roller defineres; øvelser igangsættes, men endnu ikke fuldt indarbejdet.
Recover (gendannelse og læring)	Tier 1	Tier 2–3	RTO/RPO anvendes til design af backup og gendannelsesprocedurer; regelmæssige restore-tests og post-incident reviews.

Opgave 2B – Risikovurdering (Regnbuemodellen)

2B.1 Mest kritiske aktiver

Med udgangspunkt i BIA-data:

- **Produktionsnetværk og PLC-styringer**
– gør produktion af robotløsninger mulig.
- **CAD-systemer og designfiler**
– grundlag for både produktion og udvikling.
- **AI-model for ARM-X**
– strategisk kerneaktiv og konkurrencefordel.
- **Dynamics 365 (økonomi, ordrer, fakturering)**
– central for cashflow og kundeleverancer.
- **Microsoft 365 (mail, Teams, dokumenter)**
– kommunikation og vidensdeling på tværs af organisationen.
- **Kunde- og leverandørdata**
– forretning, fakturering, relationer og GDPR-risiko.
- **NAS-backup**
– kritisk for gendannelse, men var utilstrækkelig og blev også ramt.

2B.2 Mest sandsynlige trusler (før hændelsen)

- **Phishing** og kompromitterede legitimationsoplysninger.
- **Ransomware** mod både kontor- og produktionsmiljø.
- **Industriel spionage** – tyveri af CAD-filer og AI-model.
- **Fejlkonfiguration og manglende patching** – udnyttelse af sårbare systemer.
- **Leverandørrelaterede angreb** (supply chain), fx via tredjepartssystemer.

2B.3 Regnbuematrix – før de nye tiltag

En simpel 3×3-matrix (Low/Mid/High) kan tænkes sådan her (tekstligt):

Eksempel på risikooversigt før tiltag:

Trussel	Aktiv	Sandsynlighed	Konsekvens	Risikoniveau (regnbue)
Ransomware mod produktionsnetværk	PLC, produktionsservere	H	H	Kritisk (rød)
Tyveri af CAD-filer og AI-model	CAD, AI-model	M	H	Høj (orange/rød)
Phishing mod medarbejdere	M365-konti	H	M	Høj (orange)
Nedbrud i Dynamics 365	Økonomi/ordrer	M	H	Høj (orange)
Langvarigt M365-nedbrud	Mail, Teams	M	M	Middel (gul)

Angrebet bekræfter, at “ransomware mod produktionsnetværk” faktisk var en **kritisk risiko**, og at konsekvensniveauet (10 mio. kr. direkte tab + indirekte effekter) var højt.

2B.4 Regnbuematrix – efter de nye tiltag

Efter implementering af tekniske og organisatoriske tiltag reduceres **sandsynligheden** for flere risici, mens **konsekvensen** forbliver høj (fordi aktiverne stadig er kritiske).

Trussel	Aktiv	Sandsynlighed (efter)	Konsekvens	Risikoniveau (efter)
Ransomware mod produktionsnetværk	PLC, produktionsservere	M	H	Høj (orange) – men lavere end før
Tyveri af CAD-filer og AI-model	CAD, AI-model	L–M	H	Middel–høj (gul/orange)
Phishing mod medarbejdere	M365-konti	M	M	Middel (gul)
Nedbrud i Dynamics 365	Økonomi/ordrer	L–M	H	Middel (gul)

Trussel	Aktiv	Sandsynlighed (efter)	Konsekvens	Risikoniveau (efter)
Langvarigt M365-nedbrud	Mail, Teams	L–M	M	Lav–middel (grøn/gul)

Ændringer i risikobilledet:

- Største ændring er på **sandsynlighedssiden** pga. MFA, segmentering, bedre backup og awareness.
- Ransomware og datatyveri er stadig strategiske risici, men virksomheden er mere modstandsdygtig.
- BIA og governance betyder, at risici nu bliver **systematisk vurderet og rapporteret**, ikke kun håndteret ad hoc.

Opgave 2C – Strategisk perspektiv

2C.1 Forslag til simpel informationssikkerhedspolitik

EAAA Robotics A/S – Overordnet informationssikkerhedspolitik (udkast)

Formål:

Sikre fortrolighed, integritet og tilgængelighed af virksomhedens informationer og systemer, så forretningen – særligt produktionen af robotløsninger og udviklingen af ARM-X – kan fortsætte sikkert og robust.

Omfang:

Gælder for alle medarbejdere, konsulenter og samarbejdspartnere med adgang til EAAA Robotics' systemer, data og lokationer.

Principper:>

- Cybersikkerhed er et ledelsesansvar og integreret del af virksomhedens risikostyring.
- BIA og risikovurderinger danner grundlag for prioritering af sikkerhedsindsats.
- Alle medarbejdere har ansvar for at efterleve politikken.
- Afvigelser og sikkerhedshændelser skal rapporteres straks.

Målsætninger:

- Reducere risiko for databrud og produktionsstop til et niveau, der er acceptabelt ift. virksomhedens risikovillighed.
- Sikre, at kritiske systemer kan gendannes inden for definerede RTO/RPO.
- Løbende forbedre sikkerhedsmodenheden efter NIST CSF eller tilsvarende standard.

Roller:

- Bestyrelsen godkender politik og overordnet risikovillighed.
- Direktionen er ansvarlig for implementering og ressourcer.

- En udpeget informationssikkerhedsansvarlig (CISO/IS-manager) koordinerer indsatsen.
- Systemejere og dataejere har ansvar for sikkerheden på deres områder.

2C.2 Relevante underpolitikker/standarder

Eksempler på underpolitikker, der bør ligge under hovedpolitikken:

- Adgangs- og identitetsstyring (IAM)
- Acceptabel brug af IT-udstyr og cloud-tjenester
- Backup- og gendannelsespolitik
- Incident response-politik
- Informationsklassifikation og håndtering (inkl. GDPR)
- Patch- og ændringsstyring
- Leverandør- og tredjepartsstyring
- Fysisk sikkerhed
- Logning, overvågning og brug af sikkerhedsværktøjer
- Bring Your Own Device (BYOD), hvis relevant

2C.3 Governance – hvad bør defineres

- **Roller og ansvar**
 - Bestyrelsen: fastlægger risikovillighed, modtager rapportering.
 - Direktionen: godkender sikkerhedsstrategi, budget og prioriteringer.
 - Informationssikkerhedsansvarlig: daglig styring, politikker, awareness, rapportering.
 - IT-drift: implementerer tekniske kontroller og driftsprocedurer.
 - Forretningsansvarlige (produktion, R&D, økonomi): ejer og prioriterer deres aktiver.
- **Styringsfora**
 - Et *cyber-/risikoråd* eller ledelsesforum, der mødes fx kvartalsvist for at:
 - gennemgå risikorapporter, BIA-opdateringer og større hændelser
 - beslutte investeringer i sikkerhed.
- **Procesramme**
 - Årlige risikovurderinger, årlig opdatering af BIA.
 - Plan for audits, tekniske tests og awareness-aktiviteter.

2C.4 Rapportering af cyberrisici til bestyrelsen

Forslag til **kvartalsvis** rapportering:

- **Top-risici** (fx top 5) med:
 - Beskrivelse, påvirkede aktiver, nuværende kontroller, risikoniveau (regnbuemodel).
- **Nøgletal (KPI'er/KRI'er)**, fx:
 - Andel brugere med MFA aktiveret.
 - Gennemsnitlig patch-tid for kritiske sårbarheder.
 - Resultater fra phishing-tests (klikrate).
 - Antal væsentlige sikkerhedshændelser og deres impact.
 - Resultater fra backup-restore tests op mod RTO/RPO.

- **Status på projekter og forbedringstiltag**
 - Fx etablering af SIEM, segmentering, nye policies.
- **Compliance-status**
 - Opfølgning på interne/eksterne audits, GDPR-forhold, kundekrav.

2C.5 Måling af modenhed over tid

- **Periodisk modenhedsvurdering (fx årligt)**
 - Brug NIST CSF-funktionerne og vurder Tier pr. funktion (Identify, Protect, Detect, Respond, Recover).
- **Kvantitative KPI'er**
 - Dækning af MFA.
 - Patch compliance (andel systemer, der er opdateret inden for X dage).
 - Antal kritiske sårbarheder, der står åbne > X dage.
 - Antal gennemførte awareness-moduler pr. medarbejder.
 - Tid til detektion og respons ved hændelser.
- **Kvalitativ vurdering**
 - Resultater fra øvelser (tabletops, tekniske tests).
 - Modenheden i samarbejdet mellem IT, ledelse og forretningen.

Opgave 2D – BIA og simpel beredskabsplan

2D.1 Simpel BIA baseret på BIA-data

Nedenstående BIA-skabelon samler de vigtigste data fra BIA-dokumentet.

Kritiske forretningsprocesser (uddrag)

Proces	Betydning	Kritikalitet	RTO (max nedetid)	RPO (max datatab)	Vigtigste afhængigheder
Produktion af robotløsninger (ARM-X m.fl.)	Primær omsætning, direkte koblet til virksomhedens kerneforretning	Meget kritisk	24 timer	< 4 timer	PLC-styresystemer, lokale servere, AI-modeller, produktionspersonale, leverandørlogistik
Produktudvikling og R&D	Strategisk fremtidssikring, særligt ARM-X AI-modeller og CAD	Meget kritisk	72 timer	< 24 timer	CAD, Git/repositories, AI-modeller, R&D-team
Ordre- og kundeforvaltning (Dynamics 365)	Fakturering, økonomi, leverancer	Kritisk	48 timer	< 12 timer	Dynamics 365, M365, salgs- og økonomiafdeling

Proces	Betydning	Kritikalitet	RTO (max nedetid)	RPO (max datatab)	Vigtigste afhængigheder
Kommunikation (M365 – mail/Teams)	Koordinering på tværs af organisationen	Kritisk (12–24t)	12–24 timer	< 1 time	Microsoft 365, internetforbindelse
HR og administration	Understøttende processer, kan midlertidigt køres manuelt	Lav/moderat	3–5 dage	1–2 dage	HR-systemer, M365

Konsekvensopsamling:

- Anslået direkte tab: **10 mio. kr.**, herunder:
 - 5 mio. kr. produktionsstop
 - 850.000 kr. ekstern gendannelse og hardware
 - 0,5 mio. kr. juridiske/GDPR-omkostninger
 - 2,2 mio. kr. tabt omsætning pga. mistet kundetillid
 - 1 mio. kr. værditab pga. lækgede produktdata
- Indirekte konsekvenser:
 - Medarbejderfrustration og lavere motivation
 - Tabt udviklingstid og forsinket time-to-market for ARM-X
 - Højere forsikringspræmie

Gap ift. tolerancer:

Produktion stod stille i 5 dage (RTO 24 timer) og der gik 10 dages data tabt (RPO < 4 timer) – tolerancerne var altså **kraftigt overskredet**.

2D.2 Simpel beredskabsplan (ransomware/IT-nedbrud)

Nedenfor en enkel beredskabsplan, som kan bruges som basis og senere gøres mere detaljeret.

Formål og scope

- Sikre, at EAAA Robotics kan:
 - Håndtere alvorlige IT-hændelser (fx ransomware) struktureret.
 - Minimere konsekvenser for kritiske processer (produktion, R&D, økonomi, kommunikation).
 - Gendanne drift inden for definerede RTO/RPO.

Aktivering

Planen aktiveres, når ét eller flere af følgende er opfyldt:

- Kritiske systemer (produktion, Dynamics 365, M365) er utilgængelige > 1 time uden kendt årsag.
- Tegn på ransomware, datalæk eller massiv kompromittering.
- Påvirkning af flere afdelinger samtidig.

Ansvarlig for aktivering:

- IT-chef eller informationssikkerhedsansvarlig – i tvivlstilfælde aktiveres hellere *for tidligt end for sent*.

Beredskabsorganisation (roller)

- **Kriseleder (direktionsmedlem)** – overordnet ansvar og beslutningskompetence.
- **Teknisk ansvarlig (IT-chef)** – teknisk håndtering, koordinering med leverandører.
- **Forretningsansvarlige (produktion, R&D, økonomi)** – vurderer forretningskonsekvenser, prioriterer.
- **Kommunikationsansvarlig** – intern og ekstern kommunikation (inkl. kunder og presse).
- **DPO/juridisk ansvarlig** – håndtering af GDPR og myndighedsdialog.

Faser i beredskabet

Fase 1 – Opdagelse og alarmering

- Medarbejder melder mistænkelig aktivitet til IT-support / sikkerhedsansvarlig.
- IT vurderer hurtigt: er det en kritisk hændelse?
- Hvis ja: beredskabsplanen aktiveres, kriseleder informeres.
- Start logning af alle beslutninger og tidsstempler.

Fase 2 – Begrænsning (containment)

- Isolér berørte systemer/netværkssegmenter (fx frakoble produktionsnetværk).
- Afbryd evt. internetadgang fra specifikke systemer, hvis nødvendigt.
- Deaktiver kompromitterede konti (fx brugeren fra phishing-mailen).
- Stop kryptering/proces, hvis muligt, uden at slukke alle systemer ukontrolleret.
- Involver relevante eksterne partnere (leverandører, incident response-firma, forsikring).

Fase 3 – Analyse og kommunikation

- Afklar angrebets omfang:
 - Hvilke systemer er ramt (M365, Dynamics, PLC, backup)?
 - Hvilke data er eksfiltreret (persondata, CAD, AI-modeller)?
- Vurder GDPR-konsekvenser og anmeldelsespligt.
- Informér:
 - Internt: klare instrukser til medarbejdere (hvordan må systemer bruges/ikke bruges).
 - Eksternt: kunder, samarbejdspartnere, myndigheder (hvis relevant).

Fase 4 – Gendannelse og overgang til normal drift

Genopbygning sker ud fra BIA-prioritet og RTO/RPO:

1. **Kommunikation (M365)**
 - Genskab adgang til mail/Teams, evt. midlertidig løsning (f.eks. alternative kanaler).
2. **Produktionskritiske systemer (PLC, produktionsservere)**

- Gendannelsesplan:
 - Gendan fra offline/immutable backup.
 - Test miljøet før go-live.
- 3. **Dynamics 365 og økonomisystemer**
 - Sikre dataintegritet, afstemning mod backup og papirdokumentation.
- 4. **R&D-miljøer (CAD, AI-modeller)**
 - Gendan kode, modeller og dokumentation efter prioritering.
- 5. **Øvrige systemer (HR, intranet, mindre kritiske services)**

For hvert system:

- Vælg restore-punkt i overensstemmelse med RPO (fx < 4 timer for produktion).
- Test funktionalitet og integritet.
- Frigiv systemet til drift, når ansvarlig systemejer har godkendt.

Fase 5 – Efterbehandling og læring

- Gennemfør post-incident review:
 - Hvad skete der?
 - Hvad gik godt/dårligt i håndteringen?
 - Hvilke kontroller skal forbedres?
- Opdater:
 - BIA (konsekvensforståelse).
 - Risikomatrix.
 - Policies og procedurer (fx phishing-træning, backupstrategi).
- Rapportér til bestyrelsen:
 - Forløb, konsekvenser (økonomi, drift, omdømme).
 - Plan for forbedringstiltag og status på implementering.